



File No.: EXP202313533

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: MR. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on September 13, 2023. The complaint is directed against the GENERAL DIRECTORATE OF POLICE with NIF S2816015H (hereinafter, the POLICE or the respondent). The reasons for the complaint are as follows:

The complainant states that a national police officer provided a third party with a photograph of a computer screen containing information from POLICE databases, where his personal data appeared (photo, National Identity Document (DNI), postal address, names of parents, date of birth, nationality, expiration date of the DNI, sex, place of birth).

Along with the complaint, he submitted screenshots from the instant messaging application (WhatsApp) through which the information was sent and the report filed with the POLICE. (...)

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the complaint was forwarded to the POLICE for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on October 3, 2023, as recorded in the receipt certificate in the file.

On November 22, 2023, this Agency received a response indicating that they had carried out the corresponding actions within their area of activity to ensure rights in data protection matters.

THIRD: On November 29, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On July 26, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent, C/ Jorge Juan, 6, www.aepd.es, 28001 – Madrid, sedeagpd.gob.es, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of the provisions of Articles 6.1 and 37 of Law 7/2021 of May 26, on Personal Data Protection processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and enforcement of criminal sanctions (hereinafter, Law 7/2021), classified in Articles 59 a) and 59 f) of Law 7/2021, respectively.

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement in which, in summary, it is stated:

“...this Internal Affairs Unit has received a notification from the Spanish Agency for Data Protection (AEPD), within the framework of file EXP202313533, requesting information related to the complaint filed by Mr. A.A.A. It is reported:

On September 21, 2023, this Internal Affairs Unit received an email from the Provincial Police Station of Málaga, which was assigned entry registration number ***ENTRADA.1, communicating facts that could be classified as a crime of disclosure of secrets due to the improper use of police databases. The email includes a copy of the report (...) from Málaga Central dated September 8, 2023, where A.A.A. reports that a person, later identified as B.B.B., holder of DNI ***NIF.1, had sent him via an instant messaging application (WhatsApp) a screenshot showing the Police database program (People) with his complete identification, as well as a photograph of his record.

In light of this information received, Group XX of the Internal Affairs Unit conducted an audit of police databases and concluded that the person who had consulted A.A.A.'s police record was the officer with professional ID number (...).

Therefore, given the evident indications of criminality, police proceedings number (...) of the Internal

Affairs Unit were initiated on October 27, 2023, with statements taken from those investigated without detention for crimes of disclosure of secrets and threats against B.B.B. and for the crime of disclosure of secrets against the police officer with professional ID (...), being sent to the Investigating Court on duty in Málaga.

Additionally, on November 3, 2023, a letter with registration number ***ENTRADA.2 was sent to the Disciplinary Regime Unit in order to clarify the disciplinary responsibility that the police officer with professional ID number (...) may have incurred for the improper use of police databases...”.

These allegations were dismissed, and the processing of the sanctioning procedure initiated as a result of the violation of the aforementioned articles continued within the framework of the protection of individuals regarding the processing of personal data by the competent authorities for prevention purposes,

C/ Jorge Juan, 6, www.aepd.es, 28001 – Madrid, sedeagpd.gob.es

3/12

investigation, detection, or prosecution of criminal offenses or enforcement of criminal sanctions, and to the free circulation of such data.

SIXTH: On January 7, 2025, a resolution proposal was made, proposing that it be declared that the GENERAL DIRECTORATE OF POLICE, with NIF S2816015H, has violated the provisions of:

- Article 6.1 of LO 7/2021, classified under article 59 a) of LO 7/2021.
- Article 37 of LO 7/2021, classified under article 59 f) of LO 7/2021.

SEVENTH: The resolution proposal was notified on the same January 7, 2025, in accordance with the rules established in the LPACAP. The party being claimed, on January 21, 2025, submitted, for the purpose of allegations, a report from the General Subdirectorate of Logistics and Innovation dated January 20, 2025, with the following statements:

“(..) the processing is under the protection of the controls of the National Security Scheme and complies with all its requirements.

In particular, Access Control is contemplated in the Information Security Policy of the General Directorate of Police and is developed in the procedure ***PROCEDURE.1 Access Control. However, it is not possible to prevent an authorized user from providing information (screenshots) to a third party using unauthorized means.

Likewise, the National Police conducts awareness campaigns through the intranet in the field of cybersecurity. An example image is attached.

It should be noted that there are mandatory regulations that National Police personnel should be aware of, which should deter the reported conduct.

- Organic Law 10/1995, of November 23, of the Penal Code.
- Organic Law 4/2010, of May 20, on the Disciplinary Regime of the National Police Corps.
- Basic principles of action of Organic Law 2/1986, of March 13, on Security Forces and Corps.”

Two annexes are also attached: Annex I “Decalogue” and Annex II “Report of the Training and Improvement Division on data protection training of the official (...)”, this report contains the training received by the official at the National Superior School during their promotion course.

Additionally, a report from the Internal Affairs Unit dated January 13, 2025, is provided. This report includes the facts that give rise to the present claim, as well as a summary of the actions carried out by the Internal Affairs Unit in relation to them. It is noted that the Internal Affairs Unit conducted an audit of police databases and concluded that the person who had consulted the police record of A.A.A. was the National Police officer with professional ID number (...), that police proceedings were initiated for the crime of revealing secrets against the police officer with professional ID (...), which were forwarded to the Court of Instruction on duty in Málaga, and it was also referred to the Disciplinary Regime Unit in order to clarify disciplinary responsibility.

From the actions carried out in the present procedure and from the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: The file contains a copy of the sending via an instant messaging application (WhatsApp) of a screenshot where the police database program (People) can be observed with its complete

identification (police record), as well as a photograph of the record.

SECOND: The file contains the complaint filed by A.A.A. on September 8, 2023, before the General Directorate of Police, with report number (...).

THIRD: The file shows that the POLICE, having seen its written allegations regarding the opening of the present procedure and the documentation provided, acknowledges that there was a dissemination of the police record of the claimant.

LEGAL GROUNDS

I

Competence

In accordance with the powers attributed in Article 50 of LO 7/2021 to data protection authorities and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

Finally, Article 52 "Applicable regime to the procedures processed before the data protection authorities" of Organic Law 7/2021 establishes that:

"1. In the event that the interested parties consider that the processing of personal data has violated the provisions of this Organic Law or that their request to exercise the rights recognized in Articles 21, 22, and 23 has not been addressed, they shall have the right to file a complaint with the data protection authority.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/12

2. Such claims shall be processed by the competent data protection authority in accordance with the procedure established in Title VIII of Organic Law 3/2018, of December 5, and, where applicable, the legislation of the Autonomous Communities that may apply. The general rules on administrative procedures and the legal regime of the public sector shall apply subsidiarily.

II

Applicable legal regime

Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation), establishes in its Article 2 a series of personal data processing operations to which it does not apply. Among these operations, subsection d) refers to the processing of personal data "by competent authorities for the purposes of preventing, investigating, detecting, or prosecuting criminal offenses, or for the execution of criminal sanctions, including protection against threats to public security and their prevention."

For processing of this nature, the current Organic Law 7/2021, of May 26, is applicable, through which Directive (EU) 2016/680 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of preventing, investigating, detecting, or prosecuting criminal offenses or for the execution of criminal sanctions, and on the free movement of such data, is transposed into our legal system.

In this regard, this organic law aims, according to its first article, "to establish the rules relating to the protection of natural persons with regard to the processing of personal data by competent authorities, for the purposes of preventing, detecting, investigating, and prosecuting criminal offenses or for the execution of criminal sanctions, including protection and prevention against threats to public security."

Furthermore, Article Two, by delimiting its scope of application, establishes that this regulation shall apply "to the total or partially automated processing of personal data, as well as to the non-automated processing of personal data contained in or intended to be included in a file, carried out by competent

authorities for the purposes of preventing, detecting, investigating, and prosecuting criminal offenses and for the execution of criminal sanctions, including protection and prevention against threats to public security."

III

Preliminary issues

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/12

Article 5 of Organic Law 7/2021 contains a series of definitions, in particular, it states the following:

"For the purposes of this Organic Law 7/2021, the following definitions shall apply:

a) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

b) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure, or destruction;

(...)

g) 'data controller' or 'controller': the competent authority that alone or jointly with others determines the purposes and means of the processing of personal data; where the purposes and means of the processing are determined by Union law or by Spanish legislation, such rules may designate the controller or the criteria for its designation.

h) 'data processor' or 'processor': the natural or legal person, public authority, service, or other body that processes personal data on behalf of the controller;"

In the present case, there is evidence of the processing of personal data, as a screenshot was obtained from the Police database (Persons) that contained the complete identification (police record) with the data of the claimant and was sent by a police officer to a third party via the instant messaging application WhatsApp.

IV

Violations of Organic Law 7/2021

In this case, it is established that the photo, ID card, postal address, names of the parents, date of birth, nationality, expiration date of the ID card, sex, and place of birth of the claimant were improperly exposed by a police officer, at least to one third party, through the sending (via the WhatsApp messaging application) of a photograph of a computer screen that contained such personal data recorded in police databases.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/12

For this reason, the POLICE were charged in the initiation agreement of the present sanctioning procedure with the violations of Articles 6.1 and 37 of LO 7/2021.

Article 6.1 "Principles relating to processing" of LO 7/2021 states:

"1. Personal data shall be:

(...)

f) Processed in a manner that ensures adequate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage. To this end, appropriate technical or organizational measures shall be used..."

Article 37 "Security of processing" of the LO states:

"1. The controller and the processor, taking into account the state of the art and the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the levels of risk to the rights and freedoms of natural persons, shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, especially with regard to the processing of the categories of personal data referred to in Article 13. In particular, they shall apply to the processing of personal data the measures included in the National Security Scheme.

2. With regard to automated processing, the controller or processor, following a risk assessment, shall implement control measures for the following purposes:

- a) In access control to equipment, deny access to unauthorized persons to the equipment used for processing.
- b) In control of data media, prevent these from being read, copied, modified, or deleted by unauthorized persons.
- c) In storage control, prevent unauthorized personal data from being introduced, or that such data can be inspected, modified, or deleted without authorization.
- d) In user control, prevent automated processing systems from being used by unauthorized persons through data transmission facilities.
- e) In access control to data, ensure that authorized persons to use an automated processing system can only access the personal data for which they have been authorized.
- f) In transmission control, ensure that it is possible to verify and establish to which bodies personal data have been transmitted or may be transmitted, or to whose disposal personal data may be placed through data communication equipment.
- g) In input control, ensure that it can be verified and confirmed, a posteriori, which personal data have been entered into the automated processing systems, at what time, and who entered them.
- h) In transport control, prevent personal data from being read, copied, modified, or deleted without authorization during transfers of personal data or during the transport of data media.
- i) In recovery control, ensure that installed systems can be restored in the event of interruption.
- j) In reliability and integrity control, ensure that the system functions do not present defects, that operational errors are indicated, and that stored personal data is not degraded due to system malfunctions. In this case, at the time of the events, there is no record that the POLICE had reasonable security measures in place based on the estimated potential risks.

V

Conclusions after the allegations to the Proposal for resolution

As stated, the POLICE were charged in the initiation agreement of the present sanctioning procedure with the violations of Articles 6.1 and 37 of LO 7/2021. These articles refer to the obligation of the controller to apply appropriate technical and organizational measures to ensure the security of personal data.

Regarding the technical measures, the POLICE have provided in their written allegations a report regarding compliance with the National Security Scheme.

On this particular matter, it should first be clarified that Royal Decree 311/2022, of May 3, which regulates the National Security Scheme, aims at information security by establishing the minimum necessary requirements for adequate protection of information.

Thus, the first article of said Royal Decree establishes that the aforementioned scheme "is constituted by the basic principles and minimum necessary requirements for adequate protection of the information processed and the services provided by the entities within its scope of application, in order to ensure access, confidentiality, integrity, traceability, authenticity, availability, and preservation of the data, information, and services used by electronic means that they manage in the exercise of their competencies."

Therefore, compliance with the National Security Scheme does not fully encompass the obligations imposed by Article 37 of LO 7/2021 on the controllers, as they aim not at information security, but at the protection of the rights and freedoms of individuals. From the very content of Article 37 of LO 7/2021, it is inferred that the controllers are obliged to apply to the processing of personal data the measures included in the National Security Scheme.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/12

of Security and also the measures that arise from conducting a risk assessment.

It should be added that compliance with the minimum requirements contained in the National Security Framework does not, by itself, guarantee the adequate security required by Article 6.1.f) of LO 7/2021, which goes beyond the mere application of security measures.

In fact, the second article of the aforementioned Royal Decree makes an express reference to the regulations on personal data protection when the information system processes data of that nature: “When an information system processes personal data, the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation), and in Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, or, where appropriate, Organic Law 7/2021, of May 26, on the protection of personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and the execution of criminal sanctions, the rest of the applicable regulations, as well as the criteria established by the Spanish Data Protection Agency or, within its jurisdiction, by the autonomous data protection authorities, without prejudice to the requirements established in this Royal Decree, shall apply.”

Well, as can be observed, in the case at hand, regarding the security of personal data, the regulations on data protection are fully applicable, and, in particular, given the nature of the processing, the aforementioned Organic Law 7/2021, of May 26, cannot limit the adoption of measures for the protection of personal data to compliance with the rules relating to the National Security Framework. In fact, the first additional provision of the LOPDGDD states that the National Security Framework must include the measures that must be implemented in the event of processing personal data to prevent its loss, alteration, or unauthorized access when an information system processes personal data. This mandate implicitly carries the prevalence that the protection of personal data has as a fundamental right over the National Security Framework. Thus, the National Security Framework is subordinate to the regulations on personal data protection and to the specific instruments for assessing the risk regarding the rights and freedoms of natural persons provided for in the data protection regulations, as also stated, in compliance with such mandate, in Article 3 of Royal Decree 311/2022, by determining that it will be the National Security Framework that must adapt to the criteria for determining the risk in the processing of data established in the data protection regulations, particularly as it concerns LO 7/2021.

And indeed, the data controller must take into account a series of factors such as the state of the art, the costs of implementation, and the nature, the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/12

scope, context, and purposes of the processing, as well as risks of varying probability and severity for the rights and freedoms of individuals. In this context, the data controller and the data processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk to the rights and freedoms of individuals.

In conclusion, it can be stated that the necessary compliance with the guidelines established in the National Security Scheme does not, per se, imply compliance with the obligations arising from data protection regulations; rather, it is necessary to assess, analyze, and establish technical and organizational measures that are appropriate to the inherent risk of the activity carried out.

Having established the above, it should be noted that the POLICE have not only demonstrated compliance with the National Security Scheme but also the existence of organizational measures, such

as disciplinary processes and training policies. In this regard, they have provided in their written submissions:

- (i) a "Report from the Training and Improvement Division on data protection training of the official (...)," which contains the training received by the official at the National Higher School during their promotion course in 1995, in which it is stated that they received training in, among other subjects, (...).
- (ii) a report from the Internal Affairs Unit that outlines the measures taken against the official, which include actions for criminal and disciplinary purposes. This report details the facts that give rise to the present complaint, as well as a summary of the actions carried out by the Internal Affairs Unit in relation to the same. It is noted that the Internal Affairs Unit conducted an audit of police databases and concluded that the person who had consulted the police record of A.A.A. was the National Police officer with professional ID number (...), that police proceedings were initiated for the crime of revealing secrets against the police officer with professional ID (...), which were forwarded to the Investigating Court on duty in Málaga, and that the matter was also referred to the Disciplinary Regime Unit in order to clarify disciplinary responsibility.

Furthermore, it has been established that as a result of the internal audit conducted by the POLICE, they were able to ascertain who the police officer responsible for the actions was.

In this regard, it should be recalled that, while data controllers must be accountable for the actions of their employees, this cannot be asserted when the employee uses their own means and pursues personal interests that diverge from the purposes established by the data controller. In such cases, the employee will have acted determining ends and means that are unrelated to those determined by the controller.

Therefore, it is not established that the loss of confidentiality of the claimant's data occurred due to an insufficiency or lack of effectiveness of the measures applied by the POLICE, nor even due to a lack of diligence in their application, but rather due to a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/12

action of an authorized official who failed to fulfill their obligations of confidentiality and acted for personal purposes.

Therefore, in the analyzed case, there is no evidence that would allow maintaining the accusation of the infringement of the indicated articles, and consequently, the file of the sanctioning procedure is to be processed.

Thus, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO FILE the present sanctioning procedure followed against the GENERAL DIRECTORATE OF THE POLICE, with NIF S2816015H.

SECOND: TO NOTIFY this resolution to the GENERAL DIRECTORATE OF THE POLICE.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested

party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-101224

Olga Pérez Sanjuán

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/12

The Deputy Director General of Data Inspection, in accordance with art. 48.2 LOPDGDD, due to the vacancy of the position of Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es